

Why cybersecurity could derail the infrastructure development sector's coming golden age

and how industry CIOs/CISOs should prepare for it



U.S. President Joe Biden's \$550 billion infrastructure spending law coupled with Infrastructure 4.0 plans could take our country and this industry light years ahead. However, there is an Achilles' heel that every CIO we speak with worries about as it could derail everything, yet we hold it dear to our hearts: **cybersecurity**



The infrastructure industry is increasingly adopting digital connectivity and technology to link up the supply chain across all stakeholders and suppliers, as well as using digital sensors to be the eyes and ears of the development health. While this is beneficial for the industry, it opens up the risk of cyberattacks.

Cyber incidents are predicted to cause businesses \$10.5 trillion of damages by 2025 ([Cybersecurity Ventures](#)). Unfortunately, the construction, engineering, and infrastructure industries are the most targeted by ransomware cyber attackers ([Nordlocker](#)). This is one of the main reasons that infrastructure development industry CIOs and CISOs are losing sleep over cybersecurity challenges.

Studies have shown that cybercriminals can infiltrate 93% of company networks. In 2019, at least 966 state-owned agencies were affected by ransomware attacks, causing damages of over \$7.5 billion. For CISOs, staying on top of the ever-evolving threat landscape is becoming more challenging.

The infrastructure industry cannot afford to be at the wrong end of this trend.

The real cost of cyberattacks

Average data breach costs have increased from \$3.86 million to \$4.24 million, the highest average total cost in the 17-year history of the Cost of a Data Breach Report published by the Ponemon Institute and IBM.

Monetary loss is just one of the many ways cyberattacks are damaging businesses. These are some other implications:

Tarnished reputation



Cyber incidents can lead to an inability to achieve deadlines, causing project and business delays, and thus devaluating the company's reputation. A Forbes report found that 46% of organizations had suffered reputational damage as a result of a data breach.

Threat to national security



There's been an increase in cybercriminals hacking into information related to government buildings and infrastructure (Offsite). Such intel can then be sold to terrorist or activist groups. In 2020, a hacker tried to poison a water treatment plant in the San Francisco Bay Area, endangering the lives of hundreds of thousands of people. In another incident, Colonial Pipeline, one of the largest fuel suppliers, became the victim of a ransomware attack in 2021. This caused panicked consumers to rashly attempt to carry gasoline in bins and plastic bags, risking scores of lives.

Property/intel damage and theft



Cyberattackers can hijack physical devices as well as companies' most valuable assets like product designs, technologies, and capital or planning portfolios stored on the cloud, causing operational disruption. Nearly 30% of U.S. companies have reported having their intellectual property stolen by a Chinese counterpart in the past 10 years.

Personal injuries



Extracting and leaking sensitive personal information obtained from companies' databases can also damage businesses. In 2016, The Turner Corp. fell prey to phishing emails, causing a leak of tax information of hundreds of current and former employees to a fraudulent party.

Legal complications



Entities that hold customer data are required to safeguard it appropriately. Some U.S. states have consumer data privacy laws that safeguard consumers from data breaches and can invite huge fines and legal complexities for businesses.

These irreversible damages have caused IT leaders to evolve from being mere protectors of systems and data into business enablers and champions of risk-based security programs.

Vulnerability of the infrastructure industry

Although the security awareness levels in the infrastructure industry are reasonable, the capabilities for improving security are inadequate. The sector is dealing with an array of new risks, both onsite and offsite, and it's difficult for even the most uber-careful leaders to keep pace.

Firstly, the majority of cybercrimes go unreported because many companies consider it a weakness or tarnish on their name to have suffered from an attack. Secondly, critical infrastructure companies don't know where to report cybercrimes, owing to the confusing nature of the management and reporting structure of this sector.

"The U.S. government does not treat all critical infrastructure the same," said Steven Briggs, Senior Program Manager at Tennessee Valley Authority at the virtual [CircleCityCon](#). Only three (energy, government, and nuclear) of the 16 critical infrastructure sectors listed by the Department of Homeland Security and Cybersecurity and Infrastructure Security Agency are under regulations that mandate security requirements.

WEAKNESS

Mobility and remote connectivity

RISK

Creates more points of entry where attackers could attempt to infiltrate weak (or nonexistent) security protocols.

WEAKNESS

BYOD (Bring Your Own Device)

RISK

Increased risk of falling prey to phishing emails.

WEAKNESS

Multiple transactions and vendors

RISK

Provides ample opportunity for an internal or external bad actor to wreak havoc.

WEAKNESS

Cloud-based threats

RISK

Any misconfiguration opens the door for your data to be breached.

WEAKNESS

Internet of Things (IoT)

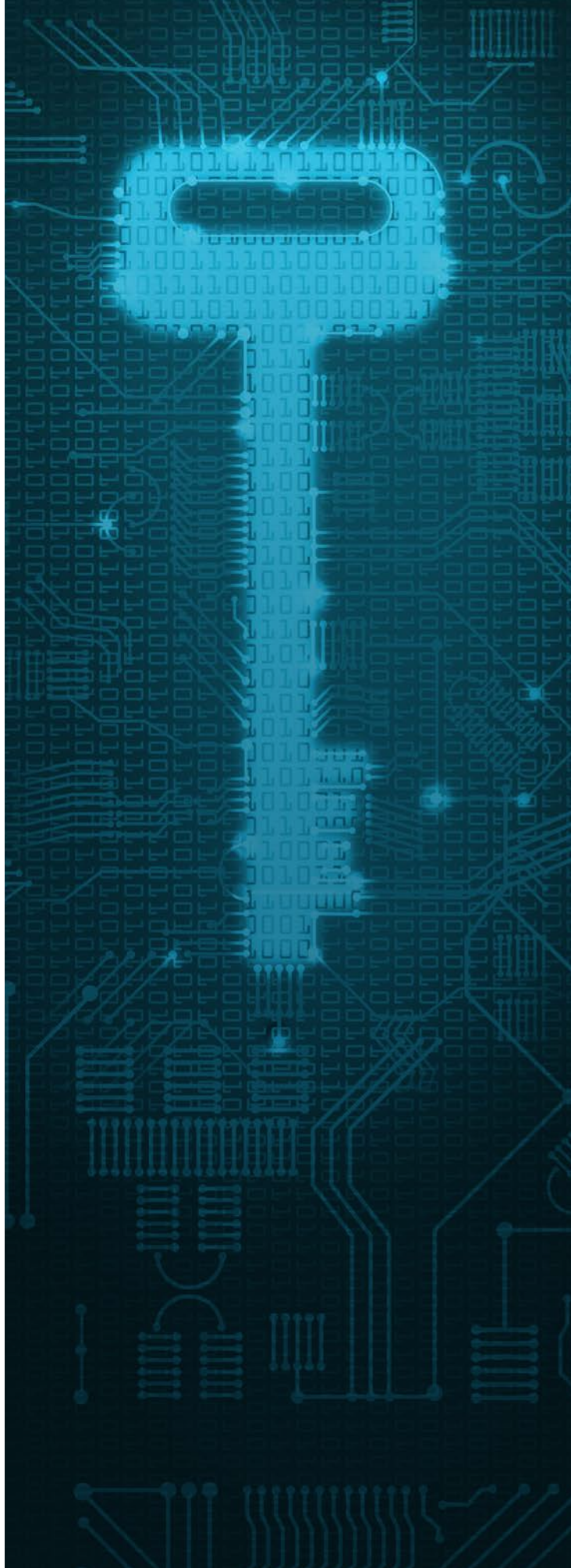
RISK

Since this is an evolving domain, it's subject to many vulnerabilities that can be easily hijacked.

How can the gap between awareness and capabilities around cybersecurity be addressed?

Tech leaders need to quickly bridge the gap between awareness and capabilities since the lack of available talent and resources required to secure networks, applications, and data are, in a very real sense, holding public agencies to ransom.

One powerful and basic way that many smart infrastructure companies are addressing cyberattacks is to educate their employees on the importance of practicing good digital hygiene around the BYOD policy. Examples include setting strong passwords, using two-factor authentication, ensuring all software is updated, conducting periodic threat analysis of their systems, securing their endpoints (VPN, anti-virus software), investing in advanced threat detection software, and cyberinsurance.



Lessons from infrastructure owners and construction giants who are tackling their security threats

Chicago Department of Water Management strengthening its security preparedness

The Chicago Department of Water Management, which operates two of the largest capacity conventional water treatment plants in the world, completed a threat and vulnerability assessment update using the J100 RAMCAP (Risk Analysis and Management for Critical Asset Protection) Standard for Risk and Resilience Management of Water and Wastewater Systems.

They did so by identifying critical assets, threats, and hazards and evaluated the cost-benefit of implementing various mitigation suites. They then created a security and preparedness capital improvement plan that prioritized the investments that the city will make to improve the security and resiliency of their critical infrastructure, thus ensuring their business continuity and security.

Bechtel achieving operational excellence with a comprehensive cybersecurity approach

Bechtel, using their APM (Asset Performance Management) system, which is their operational cybersecurity technology, helped their customers protect and operate their critical infrastructure. Their APM system does so by integrating process optimization, cybersecurity, software tools, and applications for optimizing the availability of operational assets (such as plant, equipment, and infrastructure) that are essential to the operation of an enterprise.



How to cybersecure infrastructure development—a framework

The proliferation and diversification of threat actors and their methods are some of the reasons behind the growing severity of cyberattacks. The development of sophisticated commercial tools like RaaS (Ransomware as a Service) is enabling cybercriminals to attack organizations with ease. More often than not, these hackers cannot be countered without expert intervention.

This is why security is the top priority at Aurigo. We understand that many systems in the

infrastructure industry were created before the onset of digitization. These systems are being steadily integrated with modern digital systems, leaving behind a trail of higher-than-normal vulnerabilities. Therefore, we believe in a holistic approach to security rather than implementing point solutions to challenges as they arise. Putting in place disparate solutions—as and when required—also increases the risk of being saddled with a complex security system.

Any IT system can be secured by using the following framework:

Build a solid foundation

- Select the right cybersecurity frameworks and standards for your industry and company
- Adopt a defense-in-depth approach to implement multi-layered security measures for protecting systems, applications, and data (see Figure 1)
- Adopt zero trust security architecture to eliminate implicit trust and to validate electronic interactions

Independently verify your cybersecurity maturity

- Seek industry certifications to validate the maturity of implementation (see Figure 2)
- Perform periodic third party-led penetration tests for an independent view of your security posture
- Perform “assume breach” exercises to assess the robustness of countermeasures

Monitor and maintain

- Monitor the network and systems for anomalies and suspicious activities
- Monitor and control outbound traffic and data flow to protect against data exfiltrations
- Establish a vulnerability management program to identify and eliminate vulnerabilities
- Establish a risk management program to identify, prioritize, and treat security risks continually

Partner with industry leaders

- Find strong and reliable partners to complement your team’s skills and offer support
- Assess “trusted” vendors in your supply chain for security posture maturity
- Partner with your cybersecurity insurance provider to gain a view of the security landscape

Enroll the entire company in programs for improving the cybersecurity posture

- Establish a robust security awareness program for all employees
- Establish and communicate security metrics contextualized for business needs

Continuously improve and evolve your cybersecurity posture

- Adopt an adversary mindset to identify gaps and deploy countermeasures
- Establish a threat assessment program to address emerging threats

Figure 1

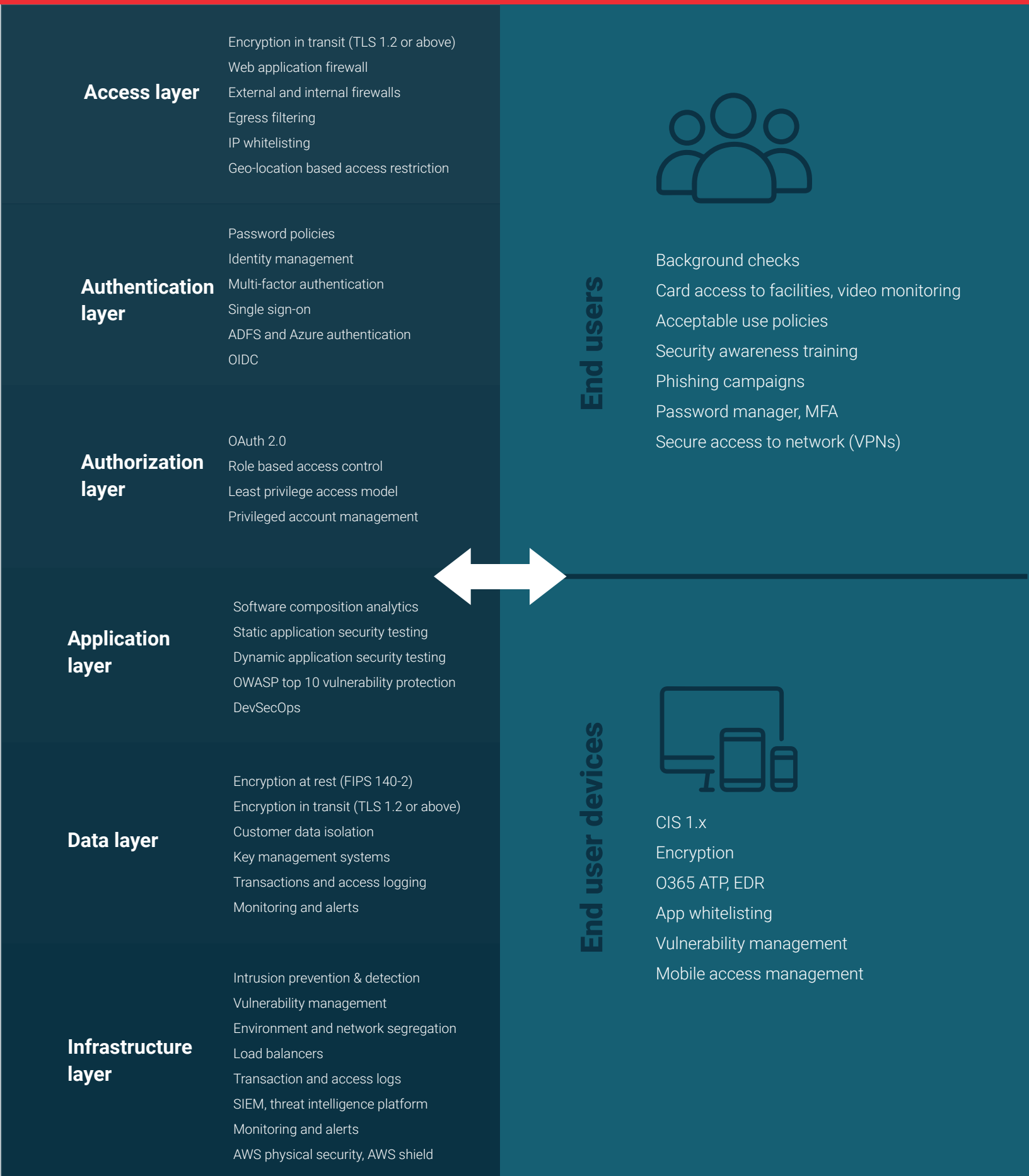


Figure 2

Aurigo: Adopted standards and industry certifications

NIST CSF, NIST 800-53 (Moderate Baseline)

NIST CSF, NIST 800-53 is a set of guidelines for mitigating organizational cybersecurity risks (by the U.S. National Institute of Standards and Technology) based on existing standards, guidelines, and practices.

CIS Benchmarks

CIS Benchmarks is a set of best practices published by the Center for Internet Security (CIS), for securely configuring IT systems, software, and networks.

FedRAMP Ready

FedRAMP is a government-wide compliance program that provides a standardized approach to federal agencies for security assessment, authorization, and continuous monitoring of cloud products and services.

StateRAMP Ready

StateRAMP is a security program established to address the needs of state and local governments in the United States. The security verification model is based on NIST 800-53 and FedRAMP.

SSAE 18 SOC2 Type 2

SSAE 18 SOC2 Type 2 is an audit that uses Trust Services Principles (by the AICPA) to evaluate the effectiveness of a service organization's controls with respect to security, availability, processing integrity, online privacy, and confidentiality.

ISO 22301:2019 (Business Continuity Management System – Disaster Recovery)

ISO 22301:2019 is a management system standard (by the International Organization for Standardization) that specifies requirements to plan, establish, implement, operate, monitor, review, maintain, and improve a business continuity management system.

AWS Government Competency

The AWS Competency Program is designed to identify, validate, and promote AWS Partners with demonstrated expertise in delivering quality solutions to help government agencies meet mandates, reduce costs, drive efficiencies, and increase innovation.

The infrastructure industry is one of the most challenging sectors for maintaining a cybersecure environment, for employees and customers alike. The huge array of interconnected devices, machines, sensors, cameras, databases, and software opens up an enormous number of entry points for cybercriminals. Businesses should be aware of these vulnerabilities and take proactive steps to protect themselves against cyberattacks.

CIOs and CISOs very well understand that the risk that comes with cyberattacks is a business issue and not a technical issue. They must ensure that they understand their company and its business perfectly so that they can assess, communicate, and manage cyber risks better.

If you're concerned that your organization may be susceptible to facing cybersecurity issues in the near future, think no more. Aurigo's security and compliance are fully equipped to meet all your needs. From being the first to offer StateRAMP-ready solutions for capital planning and project management in America to being ISO and SOC2 TYPE 2 certified, and NIST moderate baseline compliant, Aurigo is the one-stop solution for all your capital project planning, portfolio management, and data security needs.



A well-thought-out **security framework** implemented effectively can become a flywheel for powering an organization to gain customer trust and stakeholder value.

About Aurigo Software

Aurigo builds software that helps build the world. Aurigo provides modern, cloud-based solutions for capital infrastructure and private owners to help plan with confidence, build with quality, and maintain their assets efficiently. With more than \$300 billion of capital programs under management, Aurigo's solutions are trusted by over 300 customers in transportation, water and utilities, healthcare, higher education, and government on over 40,000 projects across North America. Aurigo helps capital program executives make better decisions based on proprietary artificial intelligence and machine learning technology. Aurigo is a privately held U.S. corporation headquartered in Austin, Texas, with global offices in Canada and India.

Learn more at www.aurigo.com

Schedule a demo

Schedule your demo today to learn how Aurigo Masterworks can help your organization streamline information, accurately track, forecast, and prioritize projects and help you save time and money.



aurigo®

Aurigo Software Technologies Inc.
12515 Research Blvd. Building 7 Suite 300
Austin, TX 78759
Telephone: (512) 640-3377
Fax: (631) 750 8800
aurigo.com